GMI German-Malaysian Institute

DIPLOMA PROGRAMME

THEORY TEST 2

Academic Period: July 2026

Subject	:	**INTERNET OF THINGS**
Code	:	**CBS 2383**
Duration	:	**1 HOUR**
Total Marks	:	**50**

GENERAL INSTRUCTIONS:

1. Write down clearly (with capital letters) your name, trade, group and the date of examination at the bottom of this page.
2. Do not open this question booklet until you are told to do so by the invigilator.
3. Read the specific instructions and questions carefully before answering.

This question paper consists of **9** printed pages including this page.

Student's Name	:	ABDUL HARIZ MOHD SARNUDIN
Student's I/D No.	:	CBS24070208
Semester/Trade/Group	:	SEM 5 / DCBS / CBS 1
Date	:	9/11/2026

Raw Marks:	50
Percentage (in Doc 01):	15

Question No		Full Marks	Student's Marks	CLO	Level of Difficulty	DK & DP (ETAC Programme Only)	PLO GMI PLO CBS 9 PLO - Start Intake July 2023	PLO GMI PLO CBS 11 PLO - Start Intake July 2026
Part I	1-2	2		1	3		3	2
	3-4	2		1	3		3	2
	5-6	2		1	3		3	2
	7-8	2		1	3		3	2
	9-10	2		1	3		3	2
	11-12	2		1	3		3	2
	13-14	2		1	3		3	2
	15-16	2		1	3		3	2
	17-18	2		1	3		3	2
	19-20	2		1	3		3	2
Part II	1-5	30		1	3		3	2
Part III	1-7						#N/A	#N/A
Part IV	1-5						#N/A	#N/A
Total Full Marks		**50**		**Total Student's Marks**				

SUMMARY

Note:
FM - Full Marks,
StM - Student's Mark

	CLO	Raw Marks FM	Raw Marks StM	Percentage FM	Percentage StM	PLO GMI – PLO CBS 9 PLO - Start Intake July 2023: PLO	Raw Marks FM	Raw Marks StM	Percentage FM	Percentage StM	PLO GMI – PLO CBS 11 PLO - Start Intake July 2026: PLO	Raw Marks FM	Raw Marks StM	Percentage FM	Percentag StM
Total	CLO 1	50		15.0		PLO 3	50		15.0		PLO 2	50		15.0	
	CLO 2	0		0.0		PLO 2	0		0.0		PLO 3	0		0.0	
	CLO 3	0		0.0		PLO 4	0		0.0		PLO 5	0		0.0	
	CLO 4	0		0.0		#N/A	0		0.0		#N/A	0		0.0	
	CLO 5	0		0.0		#N/A	0		0.0		#N/A	0		0.0	
	CLO 6	0		0.0		#N/A	0		0.0		#N/A	0		0.0	
Total Marks		**50**		**15.0**											

Signature	(HASYIMAH)

Part I: Answer all questions. (20 Marks)

1. Which malware specifically targets IoT devices configured with default login information, using CCTV cameras as the majority of its targets?

A. Stuxnet
B. Mirai
C. WannaCry
D. Conficker

2. What historically distinguished Operational Technology (OT) from Information Technology (IT) in manufacturing organizations?

A. OT kept the plant running smoothly, while IT managed business applications from the front office.
B. OT managed enterprise databases, while IT was confined to laboratory computing.
C. OT was primarily wireless-based, while IT relied entirely on fiber-optic links.
D. IT managed physical production lines, while OT handled accounting software.

3. Commercial personal fitness devices usually consist of which two primary sensor components to gather physical data?

A. A gyroscope and a temperature sensor
B. A blood pressure monitor and a GPS chip
C. A heart rate sensor and an accelerometer that detects motion in the form of steps
D. A galvanic skin response sensor and a blood oxygen tracker

4. In a Real-Time Remote Patient Monitoring (RPM) system, what is the role of the gateway?

A. It performs automated medical diagnostics on patient biometric data.
B. It combines signals from the body sensor network (BSN) and securely submits the data to the cloud.
C. It directly regulates therapeutic actuators worn by the patient.
D. It acts as a physical router that blocks external web browser clients.

5. Which of the following is a benefit of using a layered networking model such as OSI or TCP/IP for IoT systems?

A. It ensures that only open-source protocols are used at every network node.
B. It mandates the use of AES-128 encryption at the physical layer.
C. It removes the need for physical gateway devices in star networks.
D. It prevents technology or capability changes in one layer from affecting other layers above and below.

6. In the 7-level IoT Reference Model, which level is situated at Level 1, representing the basic physical things of IoT?

A. Physical Devices & Controllers
B. Connectivity
C. Edge (Fog) Computing
D. Data Accumulation

7. In a simple IoT layered model, what are the three basic functional domains?

A. Mist, Fog, and Cloud
B. Device, Communication, and Application
C. Identity, Reputation, and Safety
D. Physical, Logical, and Administrative

8. According to OWASP's list of hardware vulnerabilities, which threat is specifically associated with Hardware Sensors?

A. Default username and password
B. Environment manipulation
C. Removal of storage media
D. Privilege escalation

9. What is a major software operational difference between a Raspberry Pi and an Arduino board?

A. The Arduino requires a full operating system, whereas the Raspberry Pi runs compiled bare-metal machine code directly.
B. The Raspberry Pi needs a complete operating system to operate, while the Arduino compiles code and sends it to its non-volatile flash memory.
C. The Raspberry Pi is a single-board microcontroller, while the Arduino is a heterogeneous graphics processor.
D. The Raspberry Pi only supports interpreted Python, whereas the Arduino only supports compiled Rust.

10. What three pins are typically required for serial communication using a Universal Asynchronous Receiver-Transmitter (UART) interface?

A. VCC, Ground, and Clock
B. Tx (Transmit), Clock, and MISO
C. Tx (Transmit), Rx (Receive), and Ground
D. SDA, SCL, and Reset

11. What is the primary security risk of leaving the Joint Test Action Group (JTAG) port exposed on an IoT device?

A. It consumes massive network bandwidth, causing a local DoS.
B. It could allow an attacker to reverse engineer logic, extract firmware, or load malicious firmware.
C. It bypasses standard voltage regulators and fries the motherboard.
D. It forces the device's wireless transceivers into sleep mode.

12. In which IoT network topology do smart objects forward data to other smart objects to reach a gateway that may be out of range of individual nodes?

A. Mesh topology
B. Hub-and-spoke (star) topology
C. Direct-to-cloud topology
D. Point-to-point topology

13. Which of the following is the standard for low-rate wireless personal area networks (WPAN) used by low-cost, low-speed devices, specifying only MAC and PHY layers?

A. IEEE 802.11
B. Bluetooth Low Energy
C. IEEE 802.15.4
D. LoRaWAN

14. How does the ICMP amplification and reflection technique (called a Smurf attack) overwhelm a target host?

A. The attacker forwards ICMP echo requests spoofing the victim's source IP to a large number of hosts, which all reply to the victim.
B. The attacker sends a maliciously formatted TCP packet that crashes the destination router.
C. The attacker hijacks the session token and redirects DNS requests to a rogue server.
D. The attacker floods the gateway with UDP data payload checksum mismatches.

15. What is the primary difference between SQL Injection (SQLi) and Cross-Site Scripting (XSS)?

A. SQLi targets client-side web browser tokens, while XSS targets the physical gateway database.
B. SQLi modifies firmware files on an SD card, while XSS replaces microcontroller program code.
C. SQLi injects code to query and control an application's database, while XSS injects code (usually JavaScript) into the output of a web application.
D. SQLi is a local hardware attack, while XSS is a remote routing exploit.

16. Which of the following is a lightweight, publish-subscribe messaging protocol developed by IBM, which uses TCP and requires a central message broker?

A. MQTT
B. CoAP
C. XMPP
D. AMQP

17. To secure CoAP communications, what transport security protocol is recommended?

A. Secure Sockets Layer (SSL)
B. IPsec ESP
C. Datagram Transport Layer Security (DTLS)
D. Symmetric AES-128

18. Which type of vulnerability assessment involves testers who have partial knowledge of the network systems, including access to internal network architecture documentation?

A. Gray box
B. White box
C. Black box
D. Sandbox

19. In the CVSS 3.0 Calculator, which metrics belong to the Base Metric Group Exploitability category?

A. Confidentiality, Integrity, and Availability Impact
B. Attack Vector, Attack Complexity, Privileges Required, User Interaction, and Scope
C. Exploit Code Maturity, Remediation Level, and Report Confidence

D. Modified Base Metrics and Environmental Requirements

20. What is a Trust Boundary in an IoT threat model?

A. A physical tamper-proof casing around JTAG ports.
B. The interface between compiled and interpreted administrative code.
C. The symmetric key exchange channel inside low-power PANs.
D. A boundary delimiting sections of the network where the level of trust between entities is different.

Part II: Answer all questions. (30 Marks)

Question 1 (6 marks)

Contrast White Box, Black Box, and Gray Box vulnerability testing, identifying which resembles an actual external attack most closely.

White Box Testing is where the Pentester/Ethical Hacker has complete knowledge of and access to the target system's internal strucuture, including source code, network diagrams, architecture documentation and adminitrative credentials. It is comprehensive and efficient for finding deep structural flaws.

While Black Box is the polar opposite of White Box, where the tester has zero prior knowledge of the target system, receiving only the scope like an IP addresses or the hint of the services running or just a plain URL. The difference between White Box is that Pentester must perform their own reconnaissance to discover vulnerabilities and mapping the system from outside in. Basically a company would serve a Black Box as a way to find hidden vulnerabilities in their system that might be present.

While there are Black and White boxes. There are also Gray Box testing where Pentester/Ethical Hacker has partial knowledge of the system, maybe a basic user-level credentials or high level architecture documentation. It is basically a bit of combination of White Box and Black Box striking for a balance. Simulating an insider threat or attacker who has already breached the perimeter.

Each has their own purpose and benefits, but the closest to resembles an external attack will be Black Box, since it basically imitates a real world threat actors starting with no internal knowledge and must independantly discover assests, map the attack surface and find entry points.

Question 2 (6 marks)

Explain the structure and purpose of the Common Vulnerability Scoring System (CVSS) v3.0, noting its limitation regarding IoT safety.

In technical documentation or security reporting, Common Vulnerability Scoring System (CVSS) are the most important aspect as it acts as the "tag" or "mark" of how bad a newly found/discovered vulnerabilities are typically ranging from 0 to 10 where 7 to 8.9 is tagged as High and 9 to 10 is Critical.

The base metrics for this calculation is based on three(3) things, exploitability, impact and scope. Where exploitability are also consits of a few other vectors such as Attack Vector (AV), Attack Complexity (AC) and a couple other vectors. Other than the base metrics it also include Temporal Metrics (the real-world timing) and environmental metrics (your specific network).

Regarding IoT safety, which is the major flaw. The biggest issue with CVSS v3.0 is that in only cares about data and software not real-world physical safety. CVSS v3.0 measures impact strictly through the technical lens of Cofidentiality, Integrity and Availability of digital assets. It has zero concept of physical harm. Because it lacks a "Safety" metric, critifal IoT and medical bugs often get scored LOWER than they should, meaning security teams might accidentally ignore and deprioritize fixing a life-threathening flaw. For example, a smart pacemaker or heart monitoring system in a hospotal are attacked and exploited by a "hacker" or threat actor and shuts the devices down. CVSS v3.0 will only mark it as "High": since the the system is down, it mark the threat as "High" the same as a corporate web server getting shut down. It doesn't factor in that one results in a human being dying and the other just causes a minor financial headache.

This is exactly why CVSS v4.0 was eventually made to finallly add a specific "Safety" sub metric for cyber-physical systems.

Question 3 (6 marks)

Define the STRIDE threat classification scheme and provide an example threat for each category.

STRIDE is basically a threat modelling framework developed to systematically identify a software and system security threats.

1) S - Spoofing

Impersonating someone or somthing else. For example, MAC address spoofing to bypass network access control.

2) T - Tampering

Maliciously modifying data/code. For example, Intercepting and altering a software/firmware udate file before it reaches a device.

3) R - Repudiation

A user denying performing an action without the system having a way to prove otherwise. For example, an attacker clearing or manipulating system access logs to hide evidence of a breach.

4) I - Information

Exposing sensitive data. For example, a database misconfiguration leaking customer credit card numbers.

5) D - Denial of Service (DoS)

Degrading or disrupting services to they are unavailable to users. For example. flooding a web server with massive volume of botnets (DDoS) until the server crashes.

6) E - Elevation of Privilege

Gaining access level without proper authroziation. For example, exploiting a misconfiguration in a standard low-privileged users that can run admin/root commands on a certain service to perform a session hijacking that leads to the attacker gaining access to admin/root privilege.

Question 4 (6 marks)

Explain how the DREAD model is used to prioritize risks, listing its five categories and scoring range.

The DREAD model is a risk assesmsent formula to evalute cyber threats based on their severity and probability.

1) Damage - How much damage would an attack cause.

2) Reproducibility - How easily can the attack be repeated.

3) Exploitability - How much time, skill and effort is required to launch the attack.

4) Affected Users - How many users or systems would be impacted.

5) Discoverability - How easy it is for an attacker to find the vulnerability.

Each category is typically assigned a score from 1 to 10. And then the individual scores are also added together to generate an overall risk rating that dictates whether threat is low, medium or high priority.

Question 5 (6 marks)

Scenario: A retail chain with 300 locations has an embedded HTTP server vulnerability in its security camera DVRs. The manufacturer releases a patch, but the retail chain decides to tolerate the risk instead of applying the patch. Using DREAD and risk management concepts, explain how they reached this decision.

The retail chain decided to "tolerate the risk" because their risk management analysis determined that the cost and operational disruption of applying the patch outweghed the potential impact of an exploit. They likely reached this conclusion using a DREAD assesment that proved a very low overall threat score based on their specific environment.

The DVRs might only record public storefronts meaning no sensitive customer data is at risk if they were to be attacked or compromised. While the HTTP servers on the DVRs are likely isolated on an internal, segmented VLAN and not exposed to the public internet. So an attacker would breach through the corporate network just to fiind and exploit the camers which takes a LOT of work for the attacker. Other than that, a compromised camera network only impacts the loss securty team viweing the feeds, not the retail customers or the primary business operations, basically a minor inconvenience. And lastly patching the 300 physical DVRs across diverse geo-location might require dispatching technicains to perform manual USB firmware updates across all 300 locations. The massive financial and operational cost of this rollout VASTLY exceeds the low DREAD severity score leading management to validly conclude that tolerating the vulnerbility is the most cost-effective and the most effiecient approach.